EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

PLAN-RSKRSP

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. Objectives
3. Risk Response Phases
4. Communication Plan
5. Tools and Resources
6. Documentation
7. Review and Updates

PLAN-RSKRSP

1. Purpose

The Risk Response Plan outlines procedures for addressing identified risks to the organization's systems, data, and Controlled Unclassified Information (CUI). It aims to mitigate risks effectively, protect sensitive information, and ensure compliance with NIST 800-171, DFARS 7012, and CMMC 2.0 Level 2 standards.

2. Objectives

1. Mitigate risks to minimize potential harm to systems, data, and operations.
2. Protect CUI and other sensitive information.
3. Ensure continuity of operations during and after a risk event.
4. Maintain compliance with regulatory requirements.
5. Implement a standardized approach for responding to risks.

3. Risk Response Phases

Phase 1: Risk Identification

- **Sources of Risk:**
  - Internal: Misconfigurations, human error, or insider threats.
  - External: Cyberattacks, third-party vulnerabilities, or regulatory changes.
  - Physical — Loss or theft of a company-issued endpoint is considered a High-Impact Risk. This includes theft of a laptop or other endpoint from a remote work environment, giving an unauthorized party potential physical access to CUI systems and data. Controls include full-disk encryption, remote wipe capability, and mandatory incident reporting.
  - Physical — Unauthorized physical access to an unattended device is considered a High-Impact Risk. This includes household members, visitors, or other unauthorized individuals accessing an unlocked, unattended company-issued device in a home office setting. Controls include enforced screen lock and session timeout policies and user awareness training.
- **Detection Methods:**
  - Automated monitoring tools (e.g., Defender vulnerability scanners, SIEM solutions).
  - User-reported incidents.
  - Audit findings and risk assessments.

Phase 2: Risk Evaluation

-

Assess Likelihood and Impact:

- **Likelihood:** Probability of the risk materializing.
  - Determine the likelihood that threat events of concern result in adverse impacts, considering: (i) the characteristics of the threat sources that could initiate the events; (ii) the vulnerabilities/predisposing conditions identified; and (iii) the organizational susceptibility reflecting the safeguards/countermeasures planned or implemented to impede such events
  - For adversarial threats, an assessment of likelihood of occurrence is typically based on: (i) adversary intent; (ii) adversary capability; and (iii) adversary targeting.
  - Follows the Table G-2, G-3 from NIST 800-30r1 to calculate the likelihood as Very High, High, Moderate, Low, Very Low.
- **Impact:** The level of impact from a threat event is the magnitude of harm that can be expected to result from the consequences of unauthorized disclosure of information, unauthorized modification of information, unauthorized destruction of information, or loss of information or information system availability.
- Follows Table H-3 from NIST 800-30r1 to identify the Impact as one of these – Very High, High, Moderate, Low, Very Low
- **Risk** is determined based on the Likelihood and the Impact Category as per Table I-3 of NIST 800-30r1 as one of these – Very High, High, Moderate, Low, Very Low

Phase 3: Response Strategy Development

Determine the appropriate response strategy:

1. **Avoid:**
   - Modify processes or systems to eliminate risk.
   - Example: Avoid using unsupported software by upgrading to compliant versions.
2. **Mitigate:**
   - Implement controls to reduce the risk's impact or likelihood.
   - Example: Deploy multi-factor authentication (MFA) to mitigate credential theft.
3. **Transfer:**
   - Outsource risk through insurance or vendor agreements.
   - Example: Use FedRAMP-Moderate Authorized third-party cloud providers.
4. **Accept:**
   - Document the decision to accept the risk when mitigation is not feasible.
   - Example: Low-risk scenarios with minimal impact.

Phase 4: Containment

- **Immediate Actions:**
  - Isolate affected systems or networks.

- Disable compromised user accounts.
- Block malicious IP addresses or ports.

- **Incident Reporting:**

  Notify the *Security Admin* via email to incidents@atomuscyber.com or call +1 (415) 941-6745

Phase 5: Mitigation and Eradication

1. **Mitigation:**
   - Implement countermeasures to reduce risk.
   - Examples:
     - Patching known vulnerabilities.
     - Adjusting firewall or endpoint configurations.
2. **Eradication:**
   - Address the root cause of the risk.
   - Remove malware, unauthorized access, or misconfigurations.

Phase 6: Recovery

- Restore affected systems and operations.
- Verify the integrity of data and CUI.
- Conduct post-recovery monitoring to ensure no further issues arise.

Phase 7: Lessons Learned

- Conduct a post-incident review:
  - Document the timeline of events and response actions.
  - Analyze the effectiveness of the response and identify areas for improvement.
- Update policies, training, and controls based on findings.

4. Communication Plan

1. **Internal Communication:**
   - Notify relevant stakeholders – *Security Admin* and *Company Admin* of the risk and planned response actions.
   - Provide regular updates during the response and recovery phases.
2. **External Communication:**
   - Notify regulatory authorities if required as per the **PLAN-IR**
   - Communicate with affected vendors or partners as applicable.

5. Tools and Resources

1. **Monitoring and Detection Tools:**
   - SIEM solutions, Atomus tools, and endpoint detection systems.
2. **Mitigation Tools:**
   - Patching solutions, firewalls, and encryption tools.
3. **Recovery Tools:**
   - Secure backup systems and disaster recovery software.

6. Documentation

1. Maintain a **Risk Register** to track:
   - Identified risks.
   - Response actions and owners.
   - Status updates and resolution.

7. Review and Updates

- Review this Risk Response Plan annually or after significant incidents.
- Update the plan to reflect lessons learned and evolving risks.

This Risk Response Plan ensures the organization is prepared to address risks effectively, protect sensitive data, and maintain operational continuity.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "PLAN-RSKRSP".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of PLAN-RSKRSP (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026